

AI Shopping Assistant, Admin Security & the Blog Migration

Wednesday 12 August – Tuesday 18 August 2026

Solana Fireplaces · BBQ Grill Outlet · Outdoor Kitchen Outlet — shared Next.js storefront

18 COMMITTS	54 FILES CHANGED	3,160 LINES OF CODE ADDED	11 NEW MODULES	3 BRANDS COVERED
----------------	---------------------	---------------------------------	-------------------	---------------------

1. Admin access secured

The week opened by closing a hole that exposed every brand's store data to anyone who asked.

Admin was publicly reachable, and the store data behind it writable 3122589 · d394b8b

The `/admin` gate only enforced when an environment variable was set, and it never was — so every deployment served the admin interface to anyone. The only obstacle was a browser-side token check, which ran *after* the page and its data had already been sent, and could be removed with developer tools. Worse, the endpoints behind it were unprotected independently. `/api/redis` accepted unauthenticated reads, writes and deletes against any key — every brand's menus, store settings and page SEO were publicly readable and deletable in a single request, on a Redis instance all three brands share. Three further endpoints had no check at all, one of which walks an entire external catalogue for up to five minutes per call.

Operators now sign in with the account they already have 3122589

Sign in at `/login`; if the username is on the allowlist, admin access is granted for eight hours via a signed, tamper-proof cookie. Identity and authority are kept deliberately separate — the cookie proves who you are, the allowlist decides whether you are an admin, and it is read fresh on every request. Removing a name therefore revokes access on the *next request*, not whenever that person's session happens to expire.

Refusals are indistinguishable from a missing page cc4a263

Denied requests return the framework's own 404, byte-for-byte identical to any genuinely missing URL. A "403 Forbidden" confirms there is something worth attacking; this leaves nothing to compare. Each brand also received its own signing secret — verified that a cookie signed for one brand is refused by another.

Verified, not assumed

Tested against a running production build per username: all five declared admins admitted, unlisted users refused, and forged, tampered, expired and wrong-secret cookies all rejected. Denied responses were confirmed to carry no store data. Storefront unaffected throughout.

2. AI shopping assistant — built and shipped

Nine commits took this from nothing to a working assistant on all three storefronts.

A conversational assistant on every storefront page 9fe49d2 · ff2a463

Shoppers can ask what fits their space, what suits their budget, or how two models compare, in plain language. The browser never talks to the backend directly — a server-side proxy keeps credentials private and asserts which brand is asking, so BBQ shoppers can never be answered from Solana's catalogue.

Voice input uses the browser's own speech recognition: no dependency, no service, no per-minute cost.

Keyboard and screen-reader support was built in from the start, not retrofitted.

Recommendations became real product cards 7b5a1b5

The assistant recommends products as links — and *every one of those links was broken*, pointing at a URL pattern this storefront does not serve. Confirmed against production rather than assumed.

Rather than patch the model's URL, the widget now takes only the product identifier and asks our own catalogue for the real thing. The result is a card with the correct link, title, live price and an **Add to cart** button. A recommendation can no longer point at a missing page, and can no longer show a price the model invented — an unrecognised product simply produces no card.

Conversations are now kept c55006f · be623c6

Signed-in customers have their conversation stored on the backend as it happens and restored on their next visit — it survives a cleared browser and follows them to another device. Guests, who have no account to store anything against, keep theirs in their own browser for seven days, measured from the last message so an active conversation is never cut off mid-way.

Signing in or out moves the conversation with the person, and a signed-out browser retains nothing — on a shared computer, one customer's conversation must never be readable by the next.

Usage restricted to the markets we sell to e265ea0

Every message costs a model call, and the catalogue only ships to the US and Canada, so on production the assistant was limited to those two countries while remaining open everywhere else for development and demos.

Made to reach the live backend 94ac5bc · e5c0f3a

Three faults stood between the assistant and working when the backend went live: a URL from the server treated as missing, an authentication key that turned out not to be interchangeable with the general one, and product links rendered as unclickable text. The visitor's own address is now forwarded too — previously the backend's logs recorded a single address for the entire storefront.

3. Blog moved off WordPress

A separate content system retired, and a page that cost thirteen requests now costs one.

Posts now come from the main backend c9de7bb

The blog previously read from a separate WordPress installation. Listing twelve posts required **thirteen round trips**, because each post needed a further request just to resolve its image. The new endpoint returns everything inline, and an entire module of brand-mapping workarounds was deleted rather than rewritten. Two faults were found only by testing against the live API rather than trusting the specification: the obvious-looking content field is structured data, not text, and would have printed `[object Object]` on every post page; and brand filtering had to use the backend's own filter, because comparing domains directly would have rejected legitimate posts over a `www.` prefix.

Also fixed: an unknown blog URL previously returned a success response saying "No content available", telling search engines the page existed. It is now a proper 404.

4. Store accuracy & search visibility

Three different free-shipping promises, now one 2099d1f

The storefront simultaneously advertised free shipping over **\$499**, over **\$1,999** and over **\$79.99** — which promise a customer saw depended entirely on which page they happened to land on. All now read \$79.99, the confirmed policy.

Return policy published as structured data 7b383ed · ffda3a7

The return terms were held back as "unconfirmed" when in fact they had been published on the returns page the whole time. Encoded from that page rather than the shorter product-page summary, because the two disagreed on the restocking fee and the page is what a customer is actually shown. This closed the last outstanding item in the client specification that engineering could close, moving the readiness score from **95%** to **97.5%**.

5. Documentation

Porting guides for the second application 65e3c0b · be623c6

Complete implementation guides for the AI assistant and the blog, written for the separate application that runs the same backend structure under its own credentials — covering the endpoints, required parameters, regional rules and the non-obvious failure modes discovered here, so they need not be rediscovered.

Brand-isolation audit 1272061

An audit of what is genuinely separate between the three brands, answering what else changes when an operator edits one. Store settings, SEO, branding, FAQs and caches were all confirmed independent. **One exception was found and documented** — see below.

Needs attention

The AI assistant is currently open to all countries

The US/Canada restriction was deliberately lifted on 18 August so the assistant can be demonstrated and tested from the Philippines. It is a one-line change, marked in the code with restore instructions. **It should be reverted once the demo concludes** — until then, every country can generate model-call spend across all three brands.

The navigation menu is shared across all three brands

Menu content is stored without a brand prefix, so the menu editor is effectively one editor with three front doors: editing navigation, hero, featured content or collections on any brand changes all three storefronts. Documented rather than fixed, because the repair requires a data migration as well as a code change.

Shipping rates remain unpublished as structured data

Storefront copy is now consistent at \$79.99, but a claim on a page is not the same as a rate checkout will honour. Search engines treat this data as a commitment, so the field stays empty until the storefront and checkout are confirmed to agree.

Appendix — commit log

All 18 commits, 12–18 August 2026, in chronological order.

DATE	REF	TYPE	CHANGE
Wed 12 Aug	3122589	SECURITY	Gate admin on the storefront login with a username allowlist
Wed 12 Aug	d394b8b	SECURITY	Require admin auth on endpoints that read and write store data
Wed 12 Aug	1272061	DOCS	Admin access runbook, brand-isolation audit, weekly reports
Wed 12 Aug	cc4a263	SECURITY	Let the framework render the 404 instead of a hand-written one
Wed 12 Aug	2099d1f	FIX	One free-shipping threshold, \$79.99, instead of three
Wed 12 Aug	7b383ed	FEATURE	Publish the return policy as structured data
Wed 12 Aug	ffda3a7	DOCS	Rescore the readiness report at 97.5%
Thu 13 Aug	9fe49d2	FEATURE	Proxy the backend assistant behind a server-side endpoint
Thu 13 Aug	ff2a463	FEATURE	AI assistant widget on every storefront page
Thu 13 Aug	c9de7bb	FEATURE	Read blog posts from the backend API, retiring WordPress
Thu 13 Aug	94ac5bc	FIX	Reach the live assistant endpoint; make its links clickable
Fri 14 Aug	e5c0f3a	FEATURE	Forward the visitor's IP to the assistant backend
Fri 14 Aug	7b5a1b5	FEATURE	Product cards for the assistant's recommendations
Mon 17 Aug	e265ea0	FEATURE	Serve the AI assistant to the US and Canada only
Mon 17 Aug	c55006f	FEATURE	Keep guest conversations in the browser for seven days
Tue 18 Aug	65e3c0b	DOCS	Porting guide for the blogs feature
Tue 18 Aug	be623c6	FEATURE	Store signed-in conversations on the backend
Tue 18 Aug	b1bd889	CHORE	Lift the US/CA restriction for the Philippines demo